Microsoft Entra ID Lab

Microsoft Entra ID Practical Project Report

Author: Aaron Erickson
Date: October 2026
Project Type: Cybersecurity / Active Directory Lab
Platform: Microsoft Entra ID

Based on the Microsoft Entra ID training modules with independent testing, tuning and documentation.

Microsoft Entra ID home lab

The aim is to create identity lifecycle scenarios and use the Microsoft Entra ID P2 features to investigate access reviews, privileged access, Conditional access, and identity risk.

My objectives:

- Set up a fictional organisation and configure its identities.
- Perform joiner, mover and leaver scenarios.
- Configure identity security controls and Conditional Access using P2 trial.
- Conduct Access review.

1. Setting up the fictional business / Joiner procedure

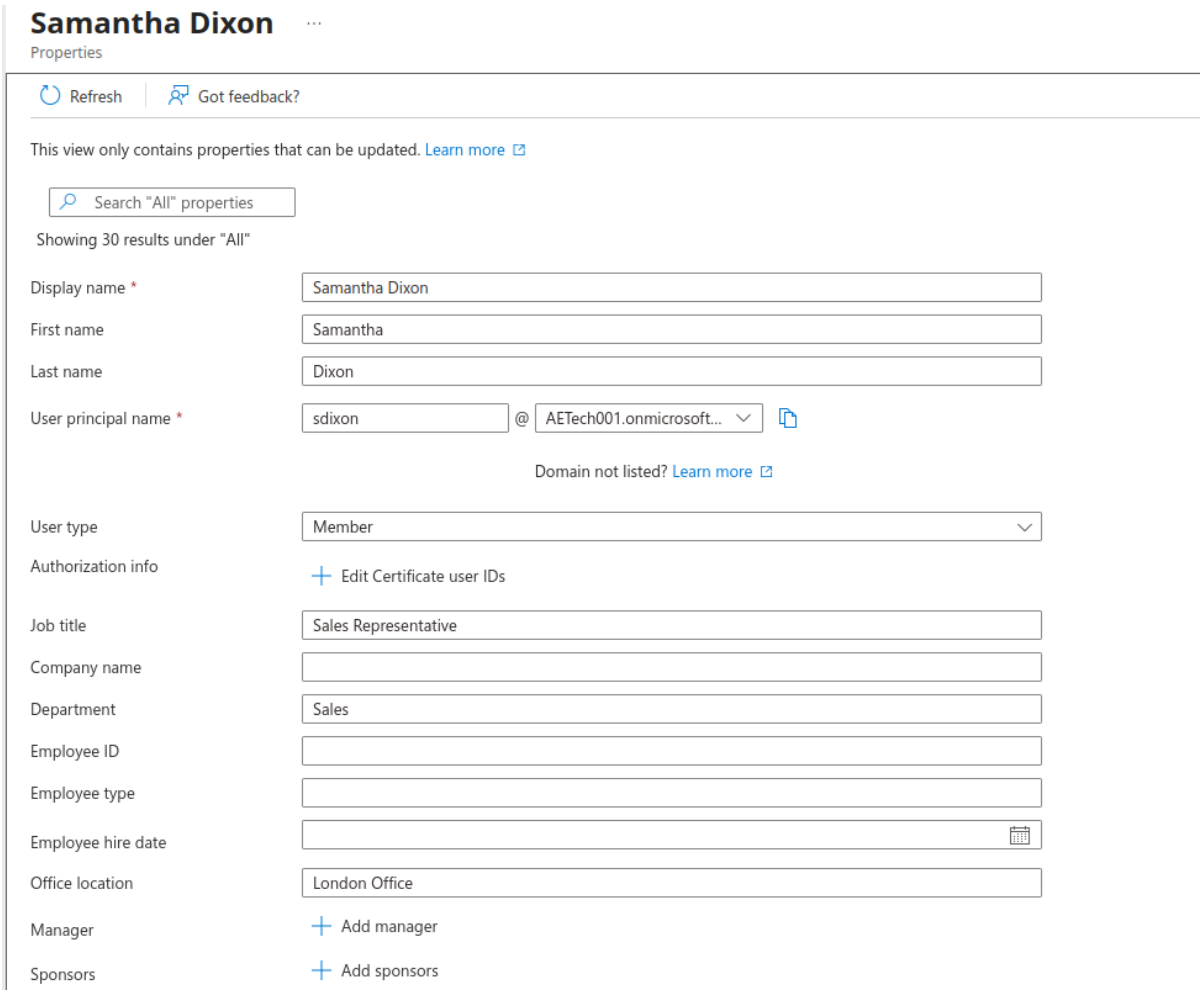


Figure 1.1: screenshot displaying an example user being created with a job title and department chosen.

For each user, I created a job title and set them to a specified department. I also set everyone's usernames as the first letter of their forename combined with their surname.

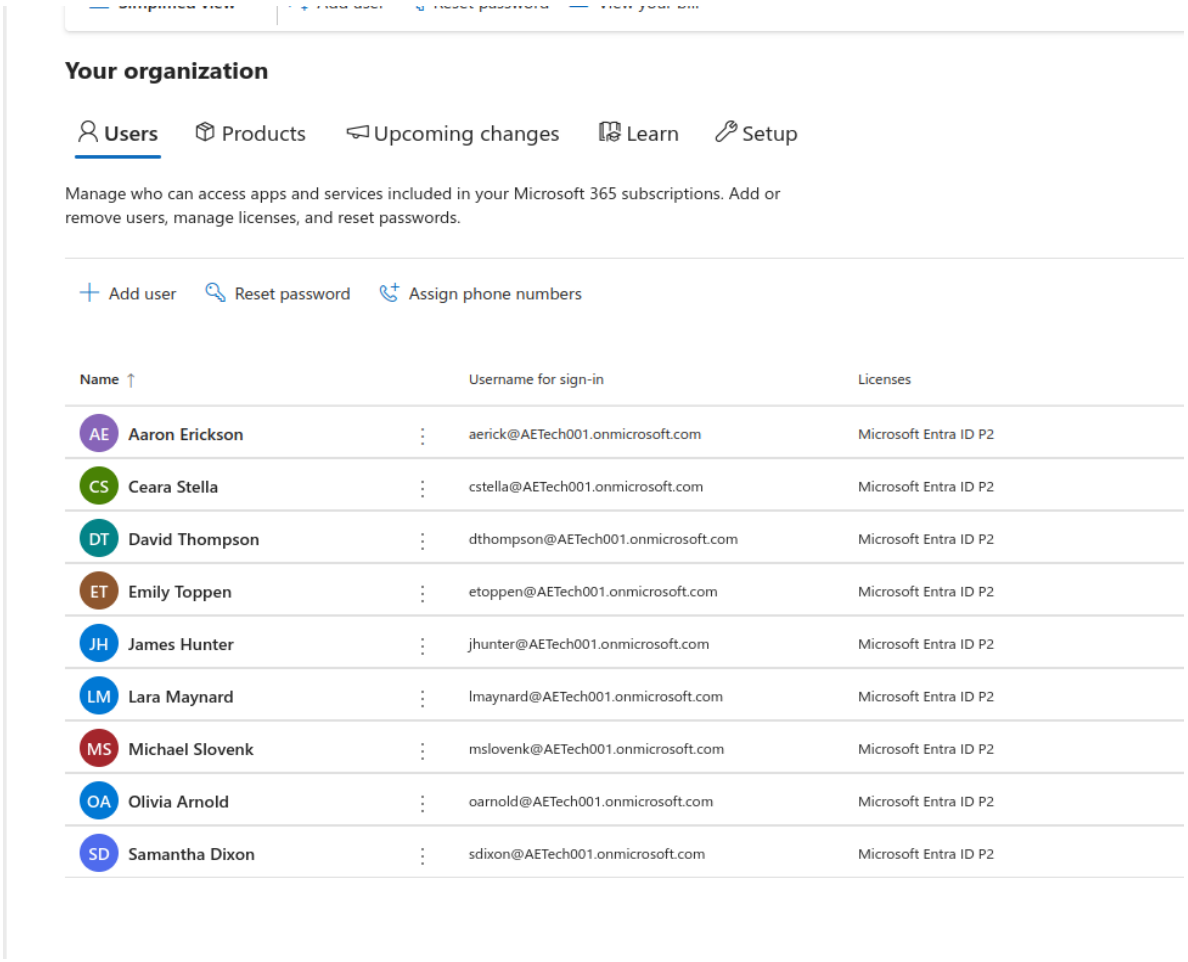


Figure 1.2: The fictional organisation so far (AETech) and it's current employees.

I have created additional users with varying job roles in one of the following departments: IT, HR, Sales, and Finance. They have been auto assigned a password upon creation and will have to change the password when logging in for the first time.
To view all the users and their respective job titles and departments, I navigated to the 'Identity' tab and selected the option to view all users.

Name	Username	Department	Job title
David Thompson	dthompson	IT	Helpdesk Admin
Emily Toppen	Etoppen	HR	HR Assistant
James Hunter	Jhunter	HR	HR Manager
Olivia Arnold	Oarnold	Finance	Finance Analyst
Samantha Dixon	Sdixon	Sales	Sales Representative
Michael Slovenk	Mslovenk	IT	Head of IT
Lara Maynard	Lmaynard	Finance	Head of Finance
Ceara Stella	Cstella	Sales	Head of Sales

Table 1.1: Shows an in-more depth of the users created with their respective departments and job titles.

The next thing I did was make security groups for each department, with the owners to each security group being the head of each department.

Group Name	Group Type	Purpose
SG-Finance	Security	Finance employees
SG-HR	Security	HR employees
SG-Sales	Security	Sales employees
SG-IT	Security	IT employees
SG-Projects	Security	For users to collaborate together on projects from specific departments.

Table 1.2: Shows the security groups made for each department.

Role	Finance Group	HR Group	Sales Group	IT Group	Projects Group
Helpdesk Admin	No	No	No	Yes	Requires justification
Head of IT	No	No	No	Yes	Requires justification
Finance Analyst	Yes	No	No	No	Yes
Head of Finance	Yes	No	No	No	Yes
HR Assistant	No	Yes	No	No	No
HR Manager	No	Yes	No	No	No
Sales Representative	No	No	Yes	No	Yes
Head of Sales	No	No	Yes	No	Yes

Table 1.3: Shows an 'Access Matrix' for each role to determine which groups they have access to, to ensure they do not have overextended permissions and to ensure the principle of 'least privilege'.

Every user I created had gone through the process of being crated, with a specific job title and department in mind, then added to the appropriate security group as specified on table 1.2.

2. Mover Procedure

For this procedure, the user 'Samantha Dixon' will be changing her job role from 'Sales Representative' to 'HR Assistant'. This means the existing department and group memberships will have to change, and specific group memberships will have to be reviewed according to the access matrix.

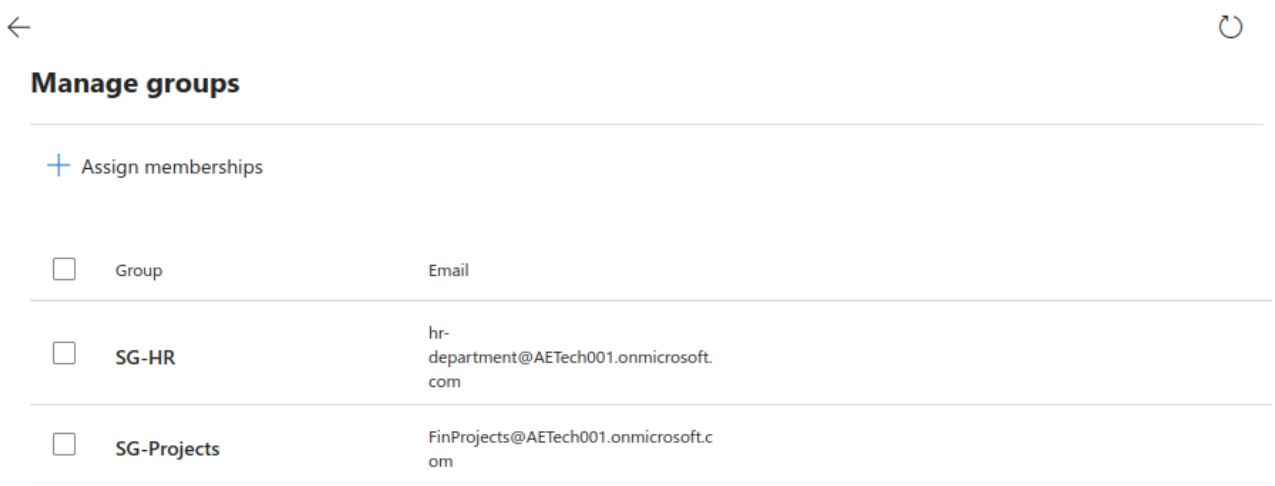


Figure 2.1: Shows Samantha Dixon's group has changed from SG-Sales to SG-HR.

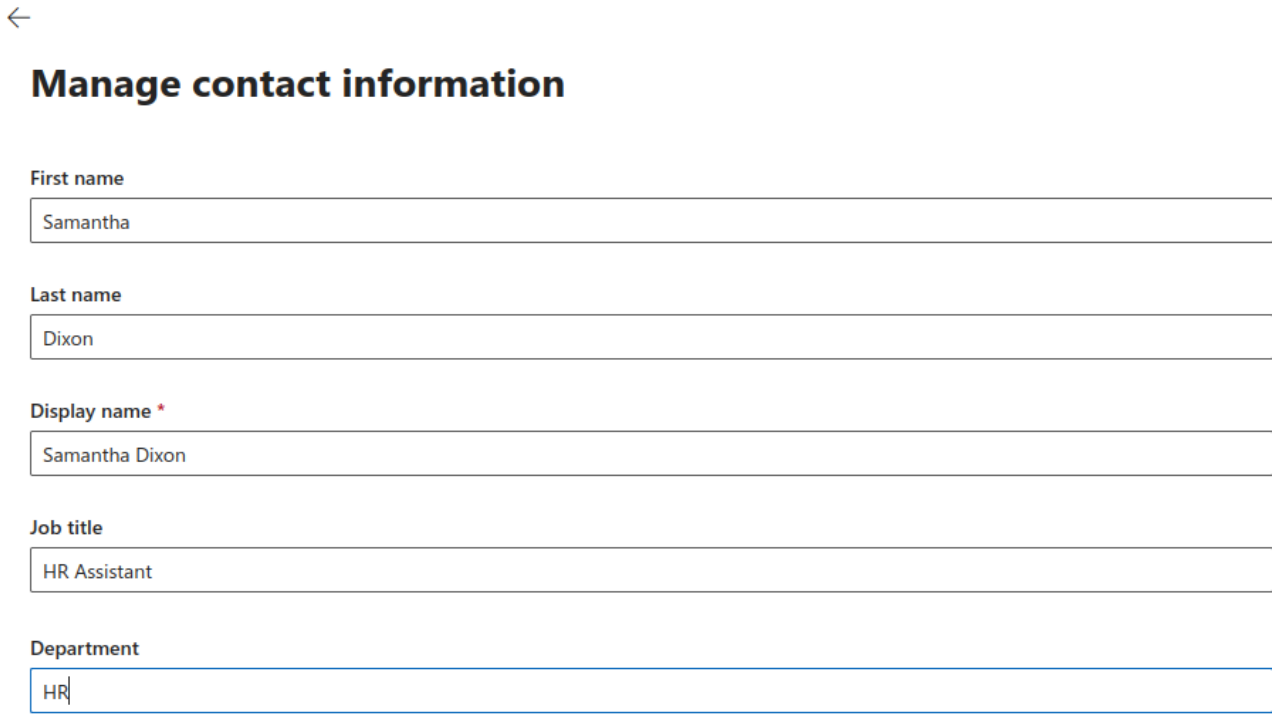


Figure 2.2: Changes made to job title and department name.

To complete the process, Samantha's membership of the 'Projects' group has to be reviewed. As of now, the group is is made for finance-based projects where departments directly involved with money will collaborate on projects to make specific reports and come up with ideas for growth. This means it is only for the Finance and Sales groups. As Samantha does not belong to either group and has transferred from 'Sales' to 'HR', this means her membership of 'Projects' must be revoked.

To make the process automated and easier, Microsoft Entra ID has an option to make 'dynamic groups' which allows for memberships to be evaluated on user attributes according to whatever rule is configured, which saves time and is easier than 'assigned membership' which is manually assigning groups.

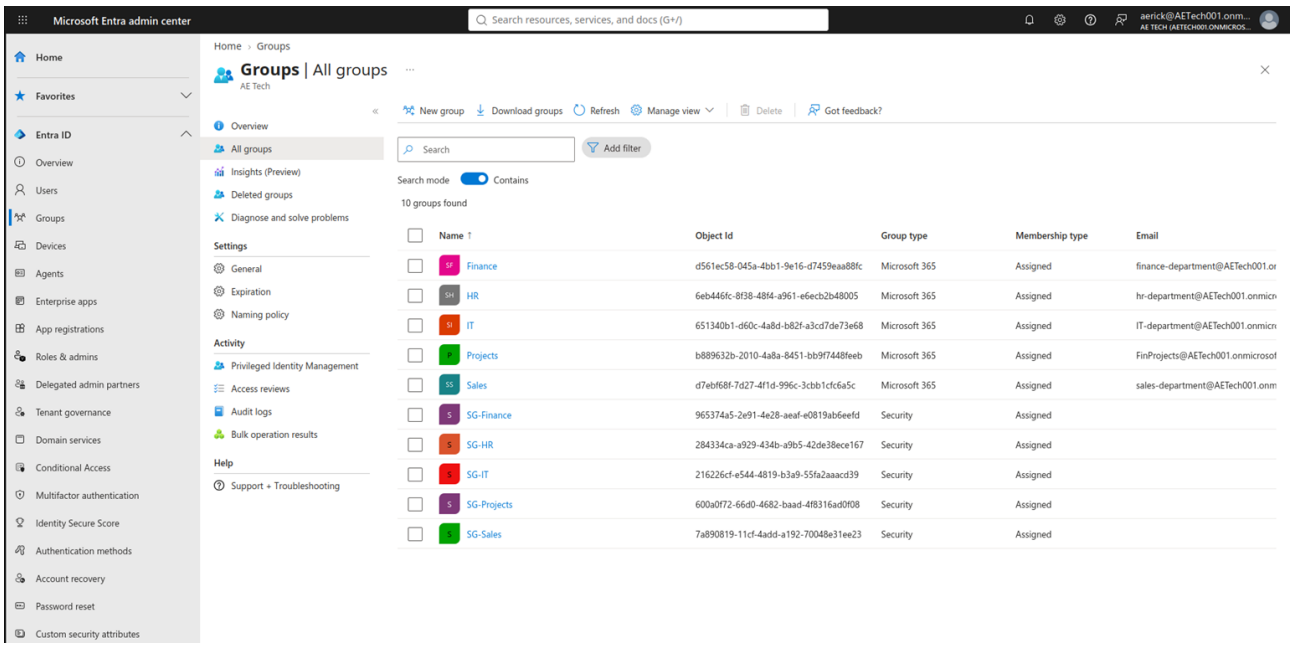


Figure 2.3: To change the membership types of groups, the Microsoft Entra admin centre had to be accessed for further modifying.

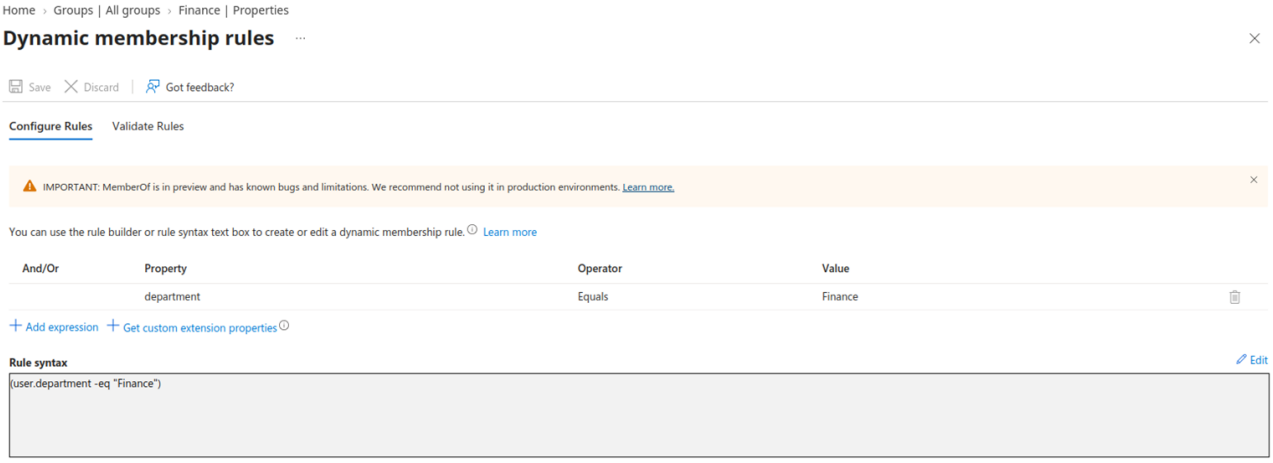


Figure 2.4: Dynamic query was added to Finance group.

To test if the dynamic query worked, a new user ‘Blake Harbinger’ was created that worked as a Finance analyst in the Finance department. Once created, I reviewed the group members of the Finance department and he has appeared.

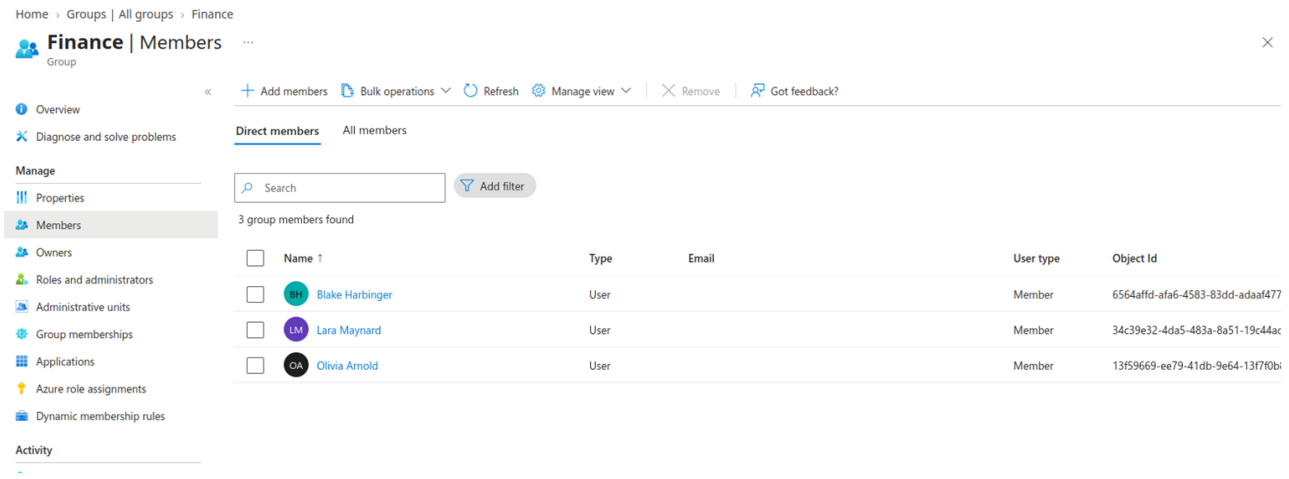


Figure 2.5: Shows Blake has appeared in the Finance group without having to manually assign him membership of the group.

3. Leaver Procedure

For this scenario, Blake Harbinger left the company and therefore his access and permissions must be reviewed and removed.

3 steps will be taken for this:

1. Block sign-in
2. Review group memberships and assignments
3. Remove memberships and assignments

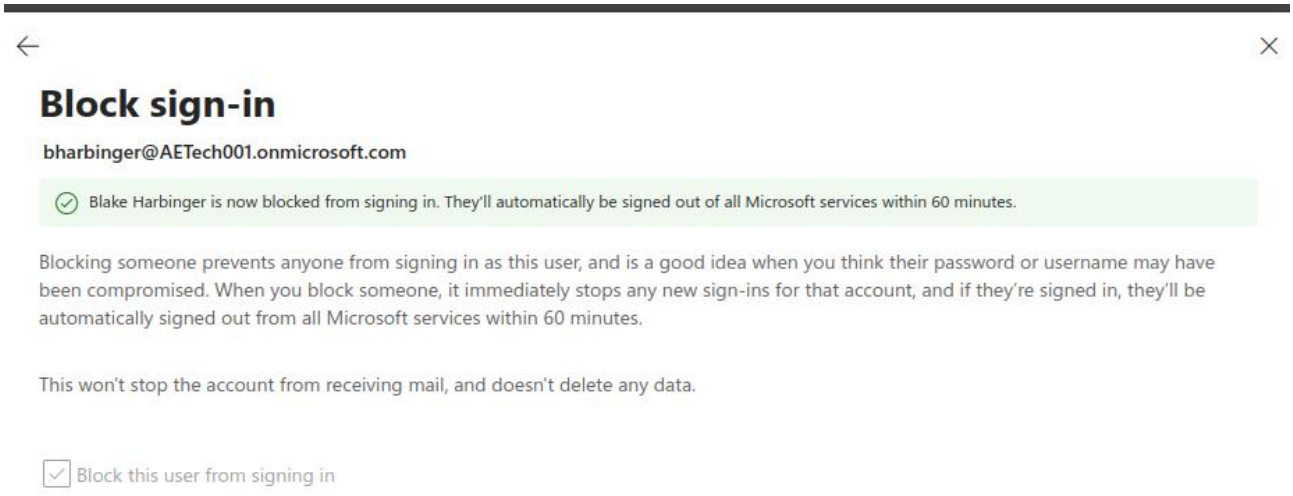


Figure 3.1: Sign-in blocking option ticked for Blake Harbinger

Check	Before	Expected After
Department	Finance	None
Job Title	Finance Analyst	None
SG-Finance	Member	Not a member
SG-Projects	Not a member	Not a member

Table 3.1: Shows Blake's access to groups before and what is expected after leaving procedure

To remove Blake Harbinger's group membership, his department had to be changed to a blank state so that the dynamic query automatically removes him from the Finance department, otherwise a privilege error would occur if trying to forcefully remove him from the group.

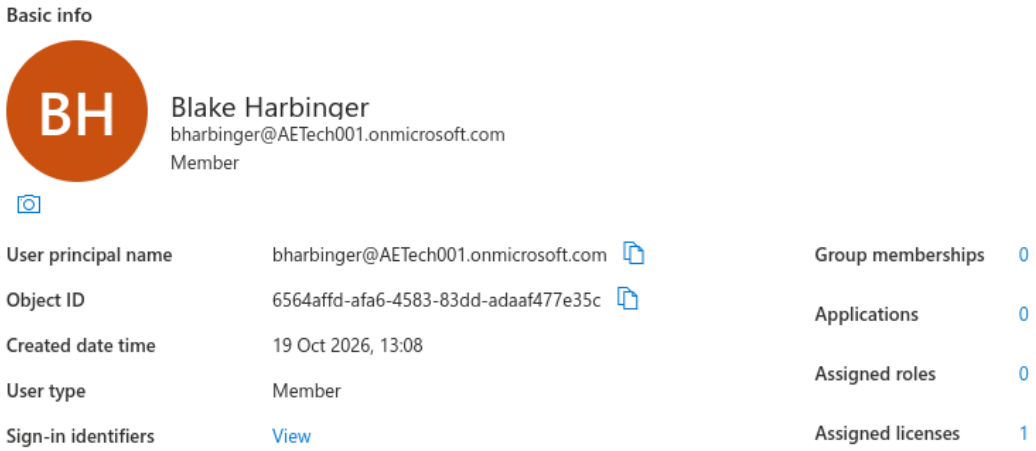


Figure 3.2: Blake is now blocked and has no group memberships.

Finally, Blake's account would be deleted but due to certain company policies that may keep the account for documenting and further potential evidence collecting, I have kept his account.

4. Privileged Identity Management (PIM)

David Thompson is currently a Helpdesk Admin. This means he may require administrator privileges to complete certain actions. In this scenario, David has been asked to cover tasks for the Head of IT and needs to be granted privileges for a week. Instead of giving him permanent access, it would be more appropriate to make him eligible to have privileged access when needed, only after being subjected to certain conditions such as Multi-Factor Authentication (MFA), a justification, and an activation time limit of 7 days.

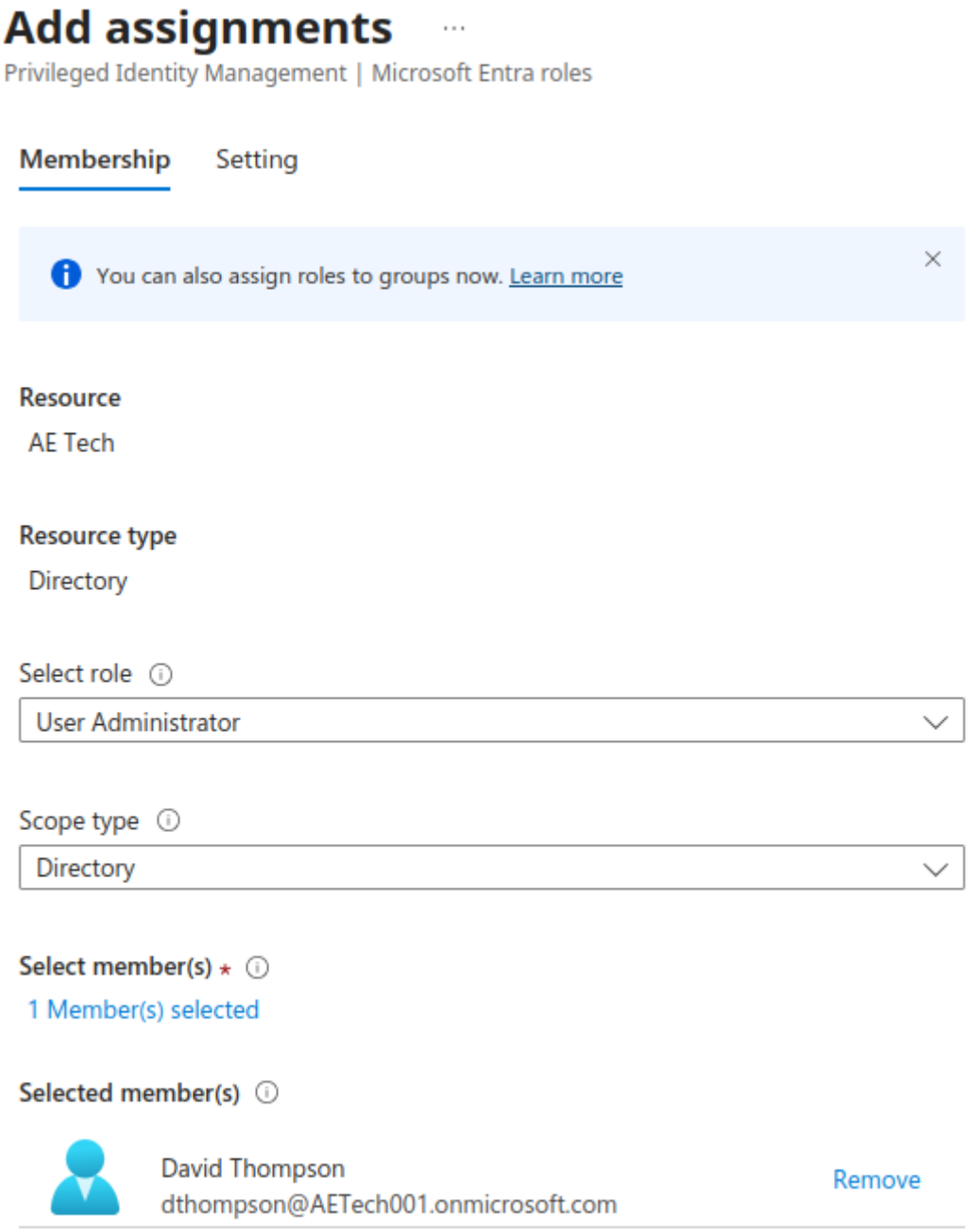
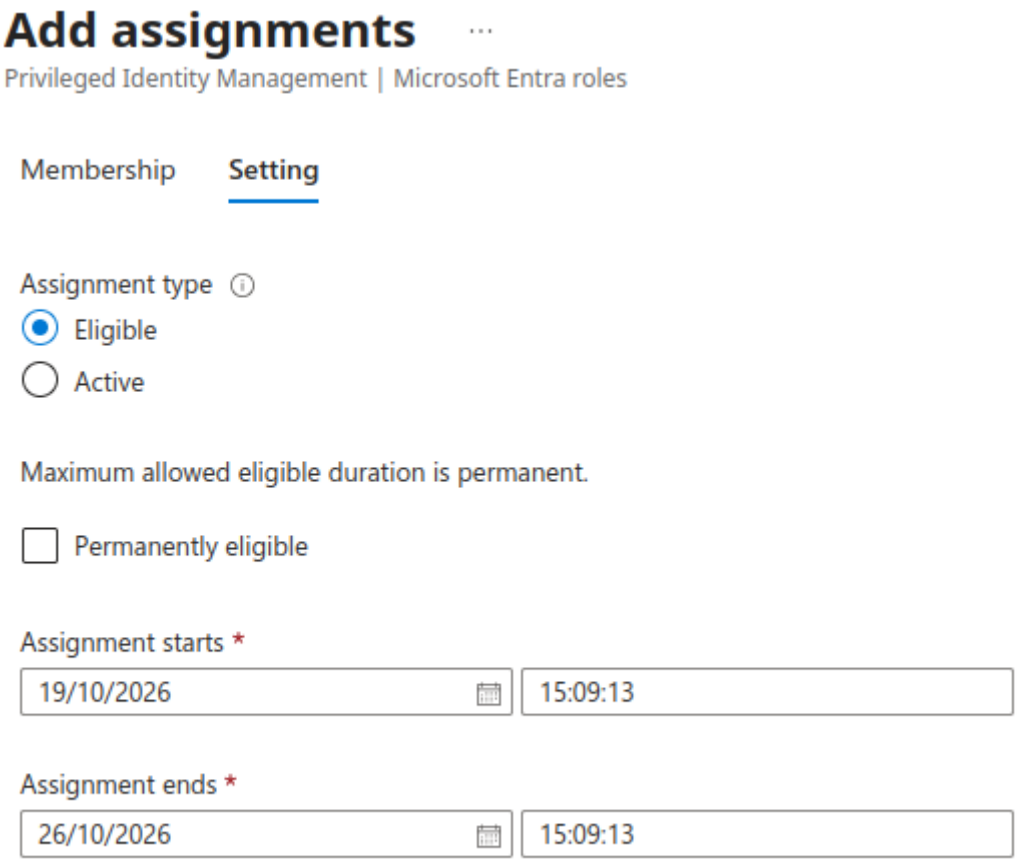


Figure 4.1: In the 'Assignments' tab under 'Privileged Access Management', David Thompson has been added as a user administrator

Figure 4.2:



Assignment type is set to eligible so that the user still has to be authenticated when using the additional privileges such as MFA. Eligible is usually chosen for users that are not assigned permanent privilege access.

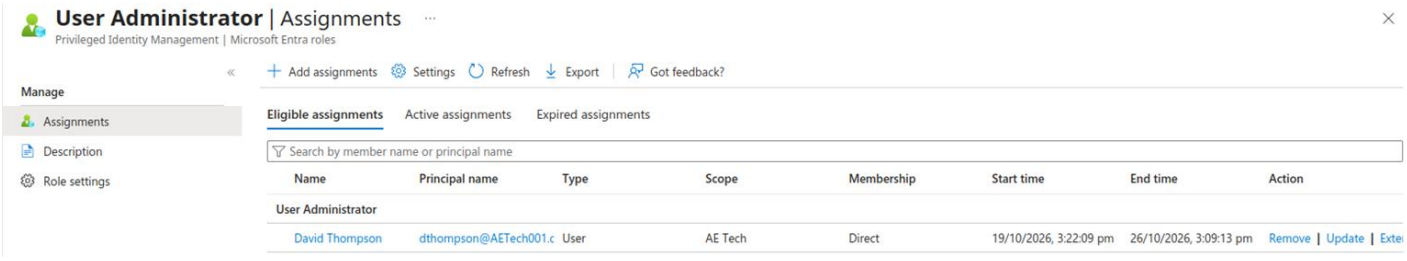


Figure 4.3: As seen above, David Thompson has been added as a user administrator with the correct time limit added on.

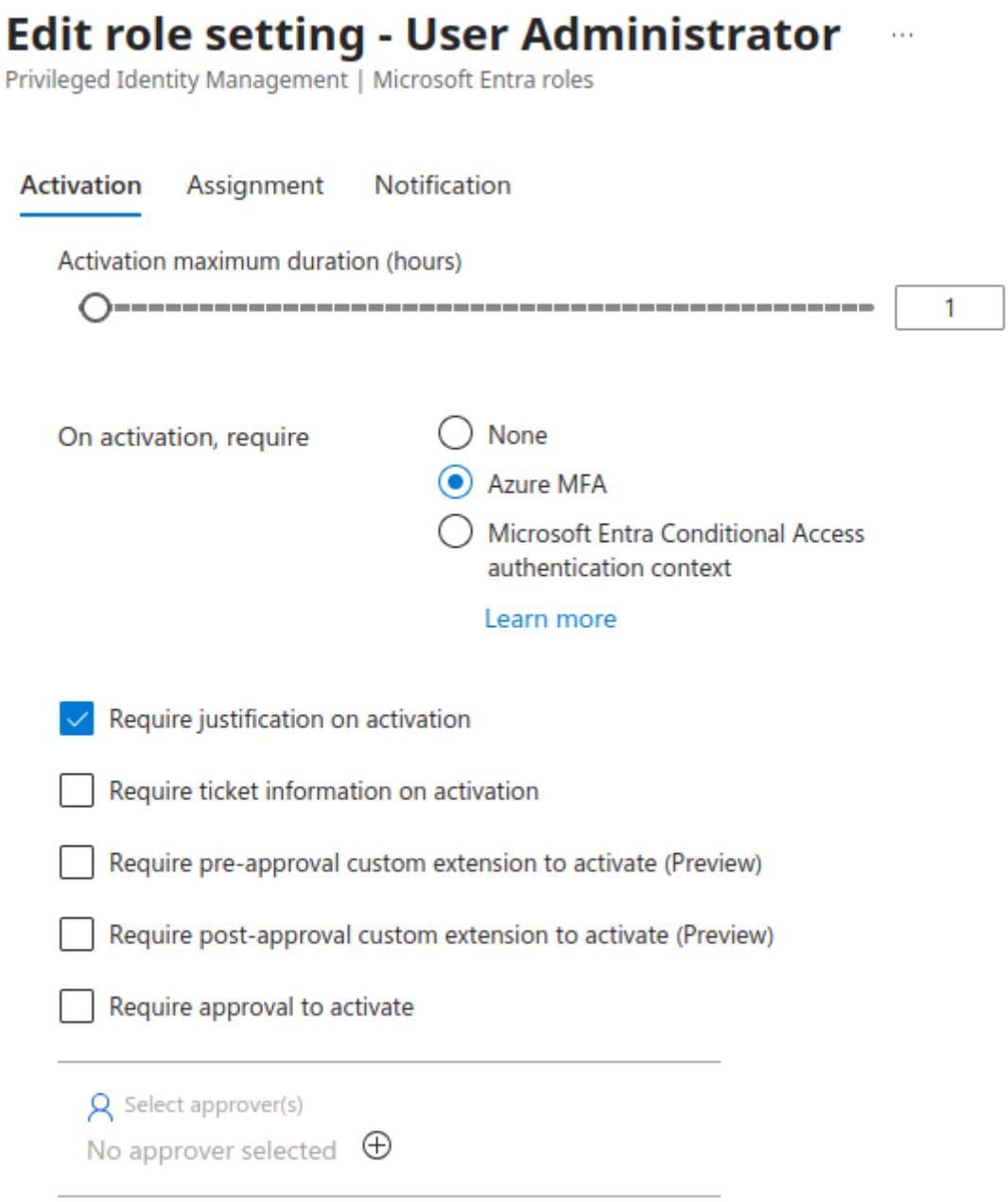


Figure 4.4: Settings for user administrator has been modified to require justification and MFA upon activation of the role.

5. Conditional Access

The next logical step is conditional access. This means managing the conditions under which someone can sign in based on policies.

Policy	Objective
Require MFA for employees	Require users to complete MFA authentication when accessing company resources
Protect privileged accounts	Require further sign-in requirements to administrators
Block legacy authentication	Prevent sign-ins using old and outdated authentication methods
Restrict access by sign-in risk	Require additional security measures when Entra detects a risky sign-in

5.1 Require MFA for employees

Table 5.1.1: This table shows the policies to make for conditional access and their respective objectives.

As conditional access policies can prevent the administrator account from signing in if configured incorrectly, the first step to undertake is protecting that account. As this is a home lab and there is only one account available as admin account for accessing the tenant, the report-only mode will be used to only observe logs made when actions take place which would normally have been blocked. To implement conditional access, a test group consisting of already existing members were made. A test group was made to experiment with policies on members without affecting the entire fictional company in case the policy has a negative impact on how users access their accounts.

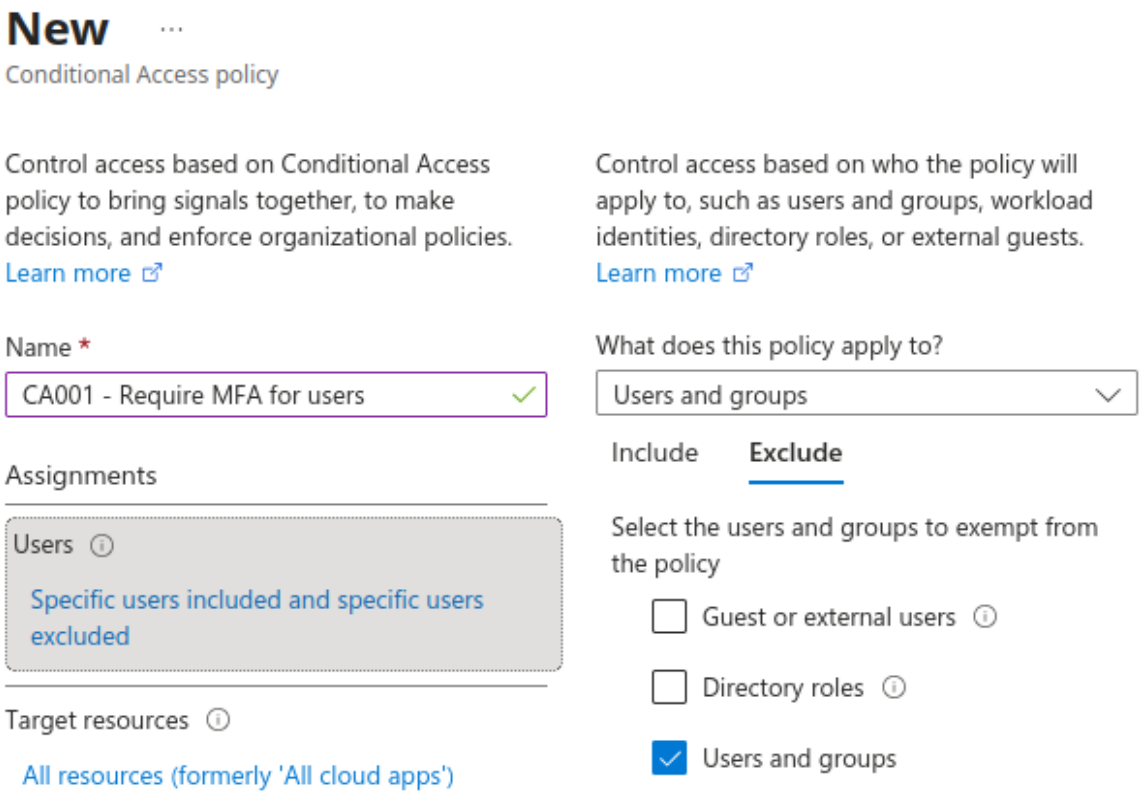


Figure 5.1.1: Conditional Access policy CA001 has been created for the test group (with my account excluded).

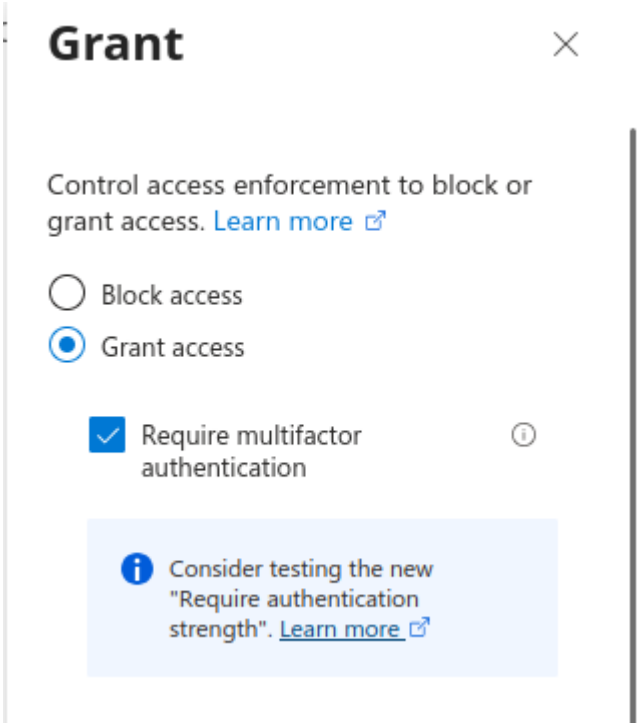


Figure 5.1.2: Access control was configured to grant access to test group users if they complete MFA.

Due to the report-only mode, the effects of the access control could be evaluated without enforcing it straight away.

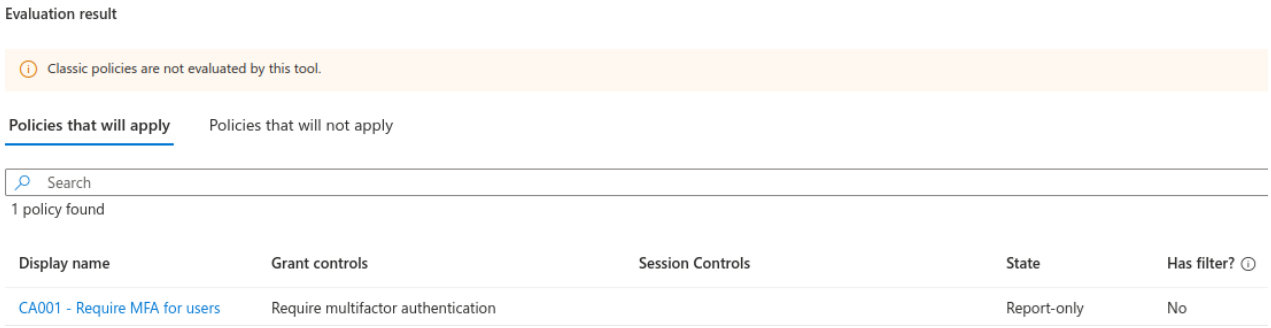


Figure 5.1.3: Shows the 'What If' function utilised.

A scenario was created in the 'What If' function of Samantha Dixon trying to access the Office 365 portal on her browser via a Windows computer. The evaluation result shows that MFA is required.

5.2 Protect Privileged Accounts

For privileged accounts, the process is the same as for the test group done before, but the users will be a higher administrative role.

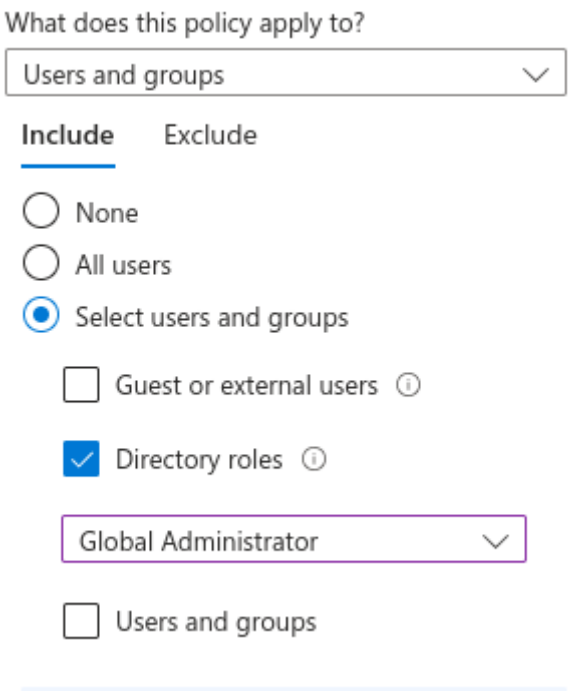


Figure 5.2.1: Global Administrator is chosen as role for MFA.

The policies made thus far has had my account excluded. As there is technically no user that has global administrator rights other than myself, to test if the policy works, I can check if it does NOT apply to my account.

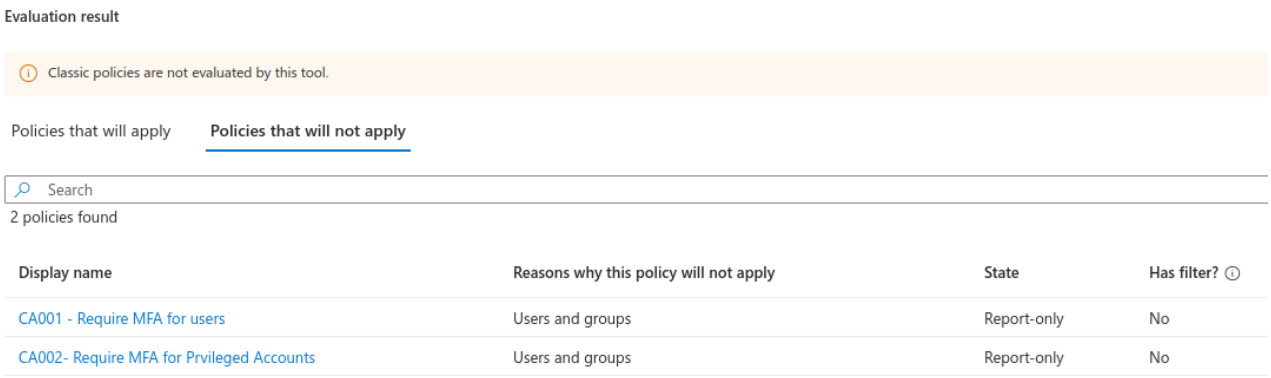


Figure 5.2.2: 'What If' evaluation shows that my account does not get targeted by both policies and therefore both policies have been applied appropriately.

5.3 Block Legacy Authentication

Enforcing a policy that blocks older authentication protocols allows for less exploitation of less secure sign-in methods. Older protocols can create difficulties when enforcing MFA and other modern protections.

The process for creating this policy follows the standard procedure of applying to all users, and targeting all resources. The difference is the 'Client apps' section needs to be configured for 'Legacy authentication clients', and to change the 'Access controls' option to block access completely.

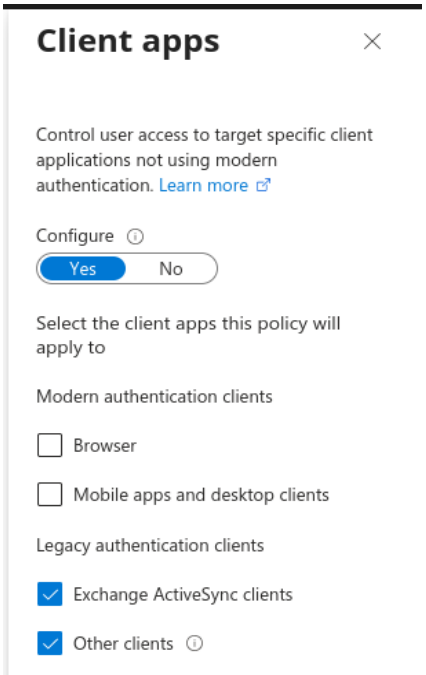


Figure 5.3.1: The figure shows that the legacy authentication clients have been checked to enforce blocked access only on older authentication methods, whereas modern ones have access via MFA.

To then test the policy, the ‘What If’ utility was used and the conditions to enable the legacy authentication blocking were entered.

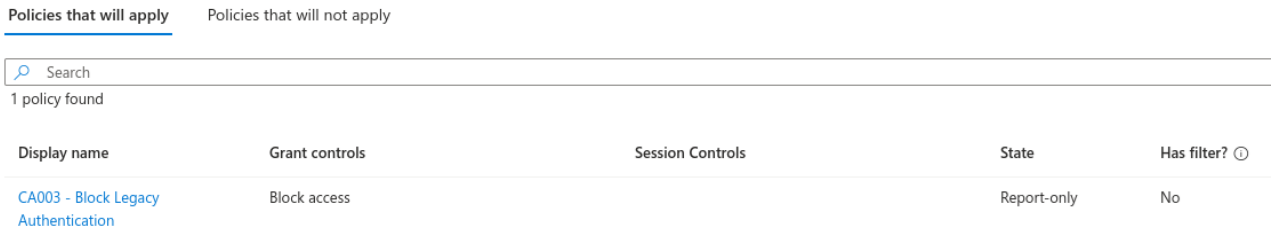


Figure 5.3.2: As seen above, the access would be blocked if any user tried to access a client app via unsupported platforms.

5.4 Risk-based Conditional Access

Sign-in risk is based on the likelihood that the particular attempt at a user authenticating is not legitimate, therefore further authentication would be necessary. MFA will be enforced when Entra identifies a sign-in to be medium or high risk.

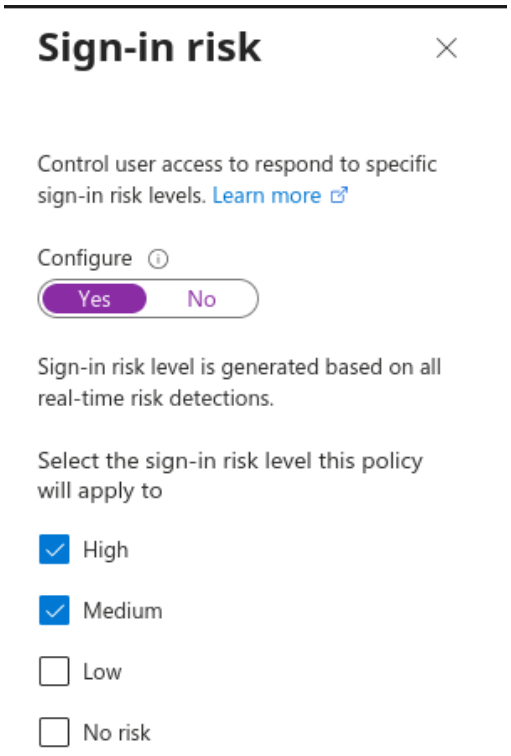


Figure 5.4.1: A new policy created with the ‘sign-in risk’ configured. MFA required was also enabled.

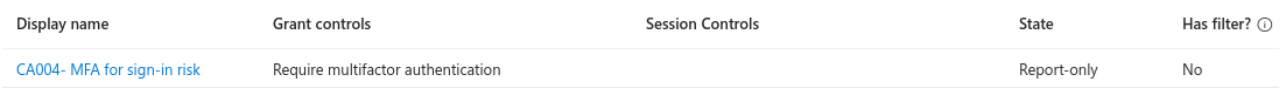


Figure 5.4.2: When tested on ‘What IF’ utility, sign-in risk was set to medium and new policy was enabled for that user.

6. Access Review

An access review allows the ability to perform an assessment of privileged roles within the organisation periodically so that users can either present a justification reason for presenting and keeping/not needing that role. It allows for monitoring of normal and privileged accounts to check whether permissions have updated.

To begin, creating a new ‘Access review’ meant navigating to the ‘Microsoft Entra roles’ and then clicking on ‘Access reviews’. The review access will be for the ‘Helpdesk Admin’ and will be run quarterly for a total of 4 times so that it ends after 1 year.

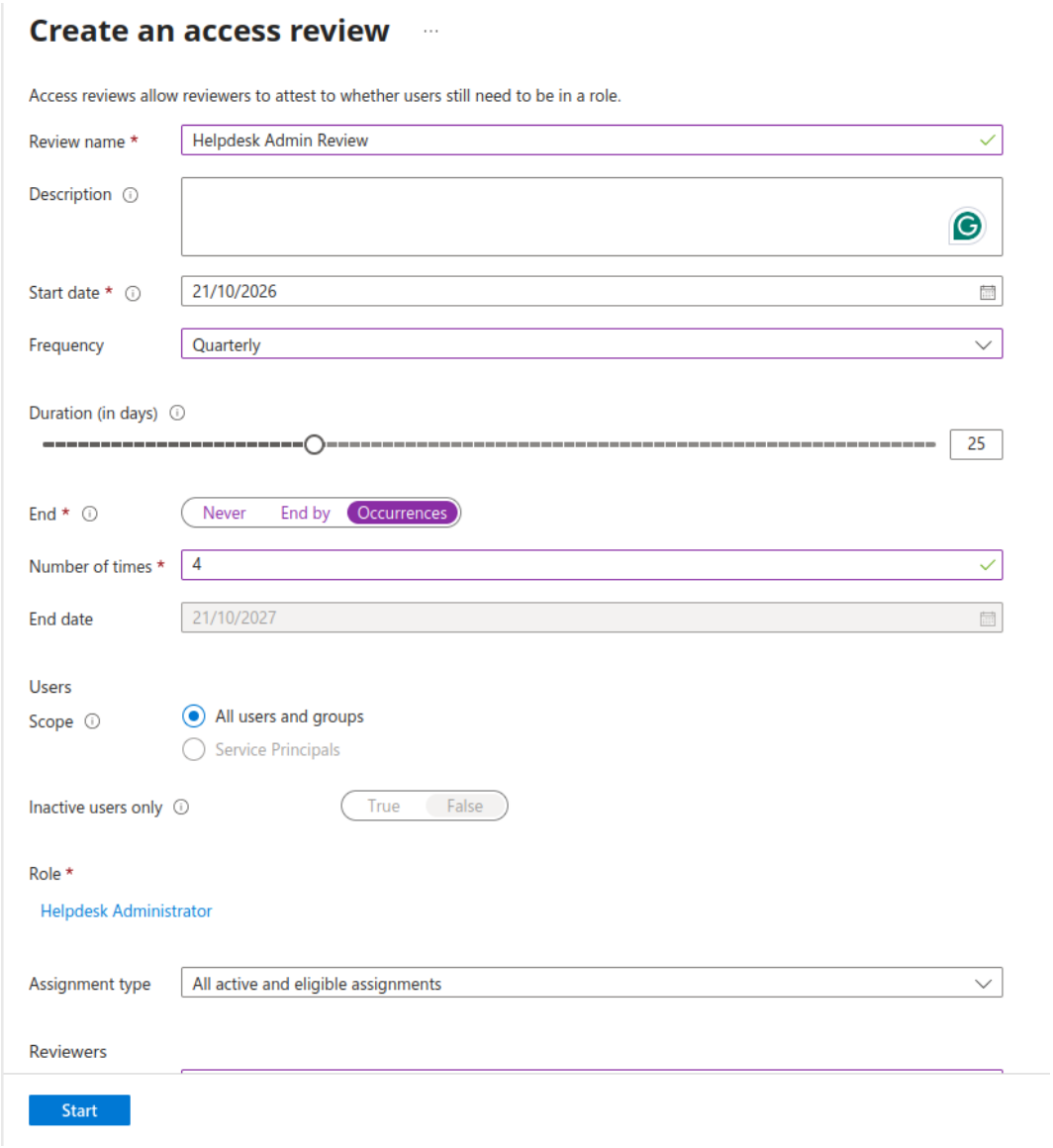


Figure 6.1: Figure shows access review settings for the ‘Helpdesk Admin’.

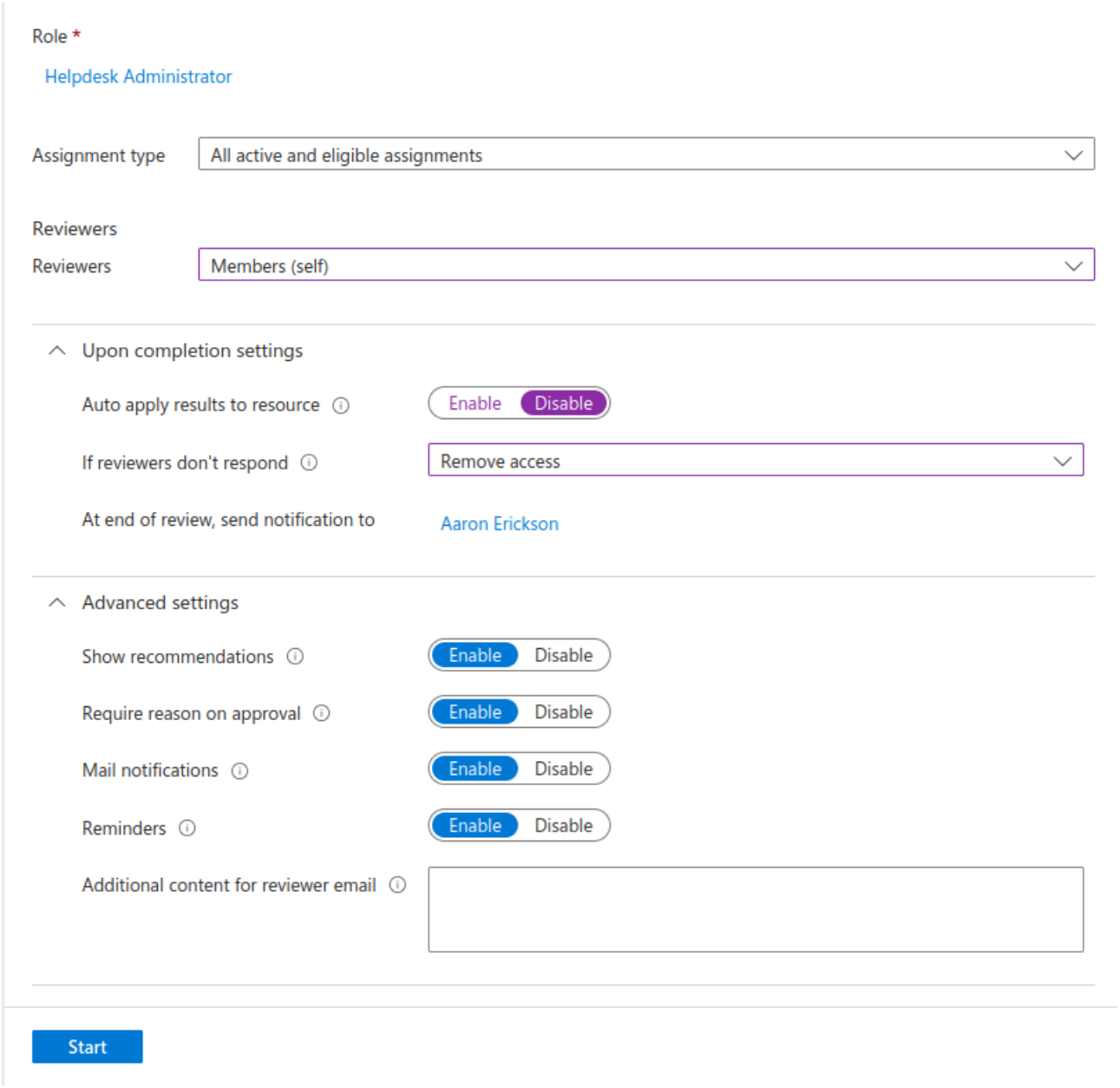


Figure 6.2: As seen above, access to conditions and role will be removed if reviewer does not respond to access review to ensure security. Notification will be sent to admin after completion.

7. Conclusion

This project provided practical experience with Microsoft Entra ID and key IAM tasks, including joiner, mover and leaver processes, group-based access, privileged access management, Conditional Access and access reviews. Testing these configurations helped me understand how organisations manage identities, control permissions and protect privileged accounts.

Although completed in a home lab, the project strengthened my practical IAM knowledge and provided a foundation for further learning and development in identity and access management.